

Kolos bezpieczeństwo:

- 1: wprowadzenie
 - ISO 27001 standard- paid resources, certifications, related publications, consultancy services a complete ecosystem
 - NIST Cybersecurity Framework (CSF) - open guidelines, useful resources
 - ENISA (EU agency for cybersecurity) - guidelines, guidance for NIS2, regulations especially for critical infrastructure systems
 - Asset - anything that has a value to an organisation
 - Information asset - a collection of knowledge or data that is organized, managed and has value
 - Held in computers, usb sticks, papers, recorded on sound and video, any other form, also stored in people
 - Information transfer - electronic - network communication - sound/written - spoken language, letters, printouts
 - Information assets should be protected at **rest and in transit**
 - Data stored is the data in the devices, Data in transit is the data moving by communication, backups and all the other exchange of data
 - Five stages of IT assets lifecycle: **planning**(requirements, development) **acquisition** (gather data ex and internally) **deployment** (assets in business processes) **management** (transfers, backup, maintenance) **disposal** (secure removal)
 - IT asset Security attributes - CIA triad - **confidentiality** (IA only available to authorised entities), **integrity** (IA accurate, complete at all times, modified by authorised entities only), **availability** (IA available for use when required, access not denied)
 - **Authenticity** (information and communication comes from a trusted source), **non-repudiation** (ensures that the creator or sender of the information cannot deny having produced or transmitted it, because there's verifiable proof of their identity.), **privacy** (the ability of a person or group to control access to their personal information and decide what they share and with whom)
 - System security - outside threads, System safety- inside threads, safety-security conflict: emergency exits, quick access to hospital

- Privacy overlaps with security - **GDPR/HIPPA**, but also conflicts, CCTV, control of financial operations, decryption of messages
- **Security Risk** - potential for losses due to an information security incident.
- Consequences can be **financial** (fines, penalties, remediation costs), **operational**, damage to **reputation**
- Unacceptable risk when the cost of consequences outweighs the cost of protection.
- Not possible to eliminate all threats. No risk doesn't exist.
- **Vulnerability** - a weakness or gap in the protection assets, **Threat** - any potential event that can cause harm to an asset or the organizational operations, **Intentional** (malware, phishing, hacking etc.), **unintentional** (user mistakes), **natural** (flood, earthquakes, fires), **Attack** - an actual intentional act of exploiting information security vulnerability,
- **Security incident** - an event that *may disrupt* normal operations because some security measures were found to be ineffective - an incident means that a successful attack is potentially possible, **Security breach** - when an *unauthorised actor gains access* to data, applications, network, or devices, resulting in information being stolen, leaked or altered. - It's a failure to protect the asset. The attack is successful.
- Reduce risk by identifying **security goals** that define security protection requirements - CIA triad, define **security policies** - rules and practices of the expected correct behavior of people and system components, implement policy with **security controls** at identified system elements and the personnel
- Security controls, measures, safeguards to protect information assets, types: **preventive** (avoid and prevent, e.g. firewalls), **detective** (logs, intrusion detection system), **compensating** (shut down, isolation of infected component), **corrective** (recover from backups).
- General schema of security management: **1.** Identify assets and security objectives (CIA) **2.** Analyse assets security to define security goals **3.** Define security policies **4.** Define and implement security controls **5.** Monitor the system and security controls effectiveness **6.** React to identified incidents and potential attacks
- **APT** - advanced persistent threat - dangerous stealthy threat actor - large groups of state-supported (China, Russia, Iran) hackers with large resources - main

areas of attack - gov, defence, finance, legal, industry, telecom - social engineering and mix of all techniques

- **Critical infrastructure** - physical and digital systems, services and assets essential for a nation's functioning and the safety of its citizens.
- 2: risk analysis and threat modelling
 - **Goals of security risk analysis:** **id** the **risk** and asses potential impact, **id** the **security controls** for all unacceptable threats and vulnerabilities, ensure **compliance**, **prioritise** the threats and security assurance tasks, **provide data** for decision makers
 - Steps: 1. Identify information assets, 2. Describe security architecture and security zones, 3. Create a risk register, 4. Define security goals, 5. Analyse internal and external threats, 6. Develop security policies to reduce risks, 7. Identify and implement security controls
 - **Step 1: id assets:** data (stored, processed, in people), software (apps, databases), hardware (servers, workstations), networks. For each define type, scope, data owner, custodian, main users, location, requirements CIA, applicable regulations
 - **Step 2: define security architecture** by Data Flow Diagram (DFD) with red dashed lines for privilege boundaries, do for all the assets, entry points including administration and technical ones
 - **Step 3: risk register** and actions to those risk, a constantly changing document, needed to be updated, proof of proactively acting on security, filled in by threat analysis, likelihood is not for random events, an attack can be anticipated and likelihood estimated
 - **Step 4: define security goals** - achieve, maintain risk level, all assets, for CIA requirements, compliant with regulations. Risk level = impact * likelihood
 - Id security goals by reviewing all assets in terms of CIA, risks and their impacts, levels, likelihood, a starting point for threat analysis
 - **Step 5: Analyse external and internal threats (modelling)** - the goal is to understand possible attacks and decide on system protection - modelling ways: use and misuse diagram (flow of actions, possible threats, security controls in place), **STRIDE: Spoofing** (authenticity - pretending to be someone else by stolen credentials), **Tampering** (integrity - modifying persistent data), **Repudiation** (non-repudiation - prohibited operations in a system that lacks

traceability - claim one didn't perform given actions), **Information Disclosure** (confidentiality - reading data without authorization), **Denial of Service** (availability - making services not available to valid users by exhausting resources e.g. DDOS), **Elevation of privilege** (authorization - gaining privileged access above the designated permission level).

- Threat analysis techniques: **attack-defence trees**: top-down from the successful attack to its causes, specify defences to specific attack paths, knowing which ways are cheap to attack, add more security there, **security bow ties**: two direction analysis of successful attacks: causes and consequences, specify barriers, defences to block an attack and reduce consequences. The results of threat analysis is an identified set of security controls to be implemented in the next steps.
- **Step 6: Develop Security policies**: a living **document** that states in writing how a company plans to **protect** its physical and information **assets**, and defines business requirements for effective security controls. types: organizational (for entire security process in the organization), system-specific, issue-specific (access, change management, disaster recovery)
- **Step 7: Identify and prioritize security controls**: estimate effort of controls implementation, set priorities depending on protection value and implementation costs, start implementing.
- 3: Physical security and human factor
 - **Challenges** for human factor: raising awareness of security risks, convincing of their reality and that they threaten business, motivate to act to prioritize security over quick business results, teaching, training, maintain culture.
 - **Types of threats**: access to physical security zones (e.g. server rooms), access to physical info (e.g. mobile devices), employees not following security procedures, mistakes, lack of knowledge, intentional attacks by insiders, employees, subcontractors, suppliers.
 - **Assess classification**: **strictly confidential** (leak could lead to even bankruptcy e.g. master passwords, access tokens, secret keys), **confidential** (leak could lead to respect loss, harm the interests e.g. personal data, source code, customer data), **internal** (intended for internal use, may be shared internally, e.g. financial data, research&dev, procedures), **public** (may be shared with 3rd parties, usually publically available online e.g. marketing materials, official reports)

- Classified information confidentiality levels in Poland: • Restricted (Zastrzeżone) • Confidential (Poufne) • Secret (Tajne) • Top secret (Ścisłe tajne)
- Physical security zones - arrange office in such a way to minimize risk of unauthorized access:
- Attackers will exploit the **weakest** link in the enterprise, so everyone should **understand** their role in the security architecture, **protect** the security and according to policies, **alert** about any noticed vulnerabilities, violations, report deviations.
- ISO 27001: **People controls** 1. Screening 2. Terms and conditions of employment 3. Information security awareness, education and training 4. Disciplinary process 5. Responsibilities after termination or change of employment 6. Confidentiality or non-disclosure agreements 7. Remote working 8. Information security event reporting **Physical controls** 1. Physical security perimeters 2. Physical entry 3. Securing offices, rooms and facilities 4. Physical security monitoring 5. Protecting against physical and environmental threats 6. Working in secure areas 7. Clear desk and clear screen 8. Equipment siting and protection 9. Security of assets off-premises 10. Storage media 11. Supporting utilities 12. Cabling security 13. Equipment maintenance 14. Secure disposal or re-use of equipment.
- Access rights; types of accounts: **standard** (limited access, only able to perform normal activities), **privileged** (admins, elevated privileges), **shared** (between people, not recommended, lower security level), **service** (used by systems and apps); limiting access rights to **need to know** - needed for only official duties, same for **the principle of least privilege (POLP)**, automatic **access rights termination**
- **Role based access control (RBAC)** - method assigning permissions based on their role in the organization
- **Authentication** - is this you? needed before authorization, **entities**: persons, systems. **vulnerabilities**: spoofing, **prevention**: protect data, **detection**: inform about new location, **correction**: disable acc in case they are breached. **Good practice**: one central auth service, single sign on, **MFA** - combination of: What you **know**? (login, password, pin) What you **have**? (access card, certificates, smartphone with tokens, biometrics)

- Controlling trust: **NDA** (mutual or non), disciplinary process, **revoking** access rights, **returning** assets
- **Remote working**: security policies for working env, use of external devices (e.g. printers), use of VPN and other networks, firewalls, antivirus, security tools, authentication from remote locations, protection of unattended devices, physical security
- **Social engineering** attacks: **phishing** - communication *pretending to be real* so a user clicks a malicious link, **Diversion theft / Spoofing** - tricking user/device into sending sensitive data to a *wrong recipient* e.g. IP spoofing, GPS spoofing, DNS spoofing. **Baiting** - presenting an *opportunity*, USB stick left in the cafe, email with promotion or discount, **Pretexting** - composing *plausible scenarios*, *pretext* to convince victim to share valuable and sensitive data, **Tailgating** - physical breach when attacker sneaks in the office by asking a person *hold the door, or grant them access*.
- **Phishing protection** - mail filtering, read carefully, ignore urgency, report, check facts, do not respond, ask colleagues
- **Security awareness training** - educate, empower, encourage, vigilance to social engineering attacks, helps build the culture of information security
- **Physical security threats**: unauthorized entry, theft and burglary, vandalism, environmental hazards (floods, fires, earthquakes), workplace violence, riots, wars. **Key components of physical security**: access control, surveillance systems, intrusion detection, external physical barriers (reinforced doors, cement blocks for vehicle threats), internal physical barriers, change management procedures
- **Security testing**: monitoring human factor (mock phishing mails), penetration tests for both human factor and physical security.
- 4: Security engineering
 - NIST CSF: **govern (GV)** - cybersecurity risk management strategy, policy established, communicated and monitored, **identify (ID)** - risks are understood, **protect/prevent (PR)** - safeguards, **detect (DE)** - possible attacks and compromises are found and analysed, **respond (RS)** - actions regarding a detected incident are taken, **recover (RC)** - assets and operations affected by the incident are restored and operational,

- **Security architecture design: conceptual** - structure for mngmt of decision making and policy enforcement across broad set of security services, **logical** - structure and relationships of the key components and services, includes all manager information assets and takes into account identified risks, **physical** - technical structure of all physical, technical and organizational security means to deliver the necessary functionality and all that, **note**: all inconsistencies to actual systems should be treated as **vulnerabilities**
- Main **rules** for security architectures: 1. Layered security (**Defense in depth**), 2. Zero Trust architecture (**ZTA**), 3. Centralized Identity and Access Management (**IAM**), 4. Security Information and Event Management (**SIEM**), 5. Resilience and Business Continuity, 6. Compliance and governance (personal data)
- **Layered Security**: *perimeter*: firewalls, DMZ, intrusion detection, *network*: network segmentation, VPN, routing, *endpoint*: antivirus, endpoint detection and response, *application*: authentication, authorization, input validation, *data*: encryption, masking, access controls, *user*: awareness, training, and phishing protection.
- **Zero trust architecture (ZTA)** - never trust, always verify, every request, internal, external must be authenticated, authorized and encrypted. **Principles**: verify explicitly, least privilege, assume breach, microsegmentation, continuous monitoring and analytics,
- **Conceptual security architecture** - basis for further development, security policies and models for each management system: identity, access, configuration, cryptographic services, security zones, dev-operation-staging envs, info content control, backups and recovery, threat detection, auditing, **aspect to consider**: business and security goals, compliance requirements.
- **Identity management** - for assets in the organization and external assets, IAM services, policies, RBAC, online/offline authentication - design and identify all systems involved in the identity management.
- **Access mng** - centralized system - RBAC - MFA - least privilege
- **Cryptographic services** - user **authen**, **authorisation**, protection of data in transfer **HTTPS/TLS 1.2 / FTPS** (SSL - unsecure), protection of data at rest - **data** volume **encryption**, **signing** services for code, apps, docs, info assets, **crypto keys** essential, design the **mng** of the **keys** and **store securely**.

- **Security zones - secure app networking** - VPN only with MFA, firewalls, DMZ, db without direct external access, subnetworks, routers, WiFi only after risk consideration, forward/reverse proxy, gateways
- **Device Security** - *physical* (detect connecting USB sticks, encode data to prevent reading when device is stolen), *network* (VPN, connection to the org not device), *monitoring* (self-checks, device monitoring, scanning in sandbox env)
- Map physical security zones to devices: servers, pcs, mobiles, information media, network, cabling
- **Info content control** - anti spam, antivirus, antimalware, IDS, network monitoring, control of connected devices, app installation control, data consistency checks, availability checks, backup checks
- Communication channels for reporting threats, **Security info and event mng (SIEM)** aggregates logs, analysis, notifies user about suspicious activity, **SOAR - Security Orchestration, Automation and Response** - based on SIEM, finds risk, orchestrates response workflow, automated when possible,
- **Auditing services** - store logs securely, collect, classify, don't log too much too little, no sensitive info, backup.
- **Dev, staging, test, production env**
- **Maintenance and changes to security architecture** - should be secure during the change, develop process for conducting change, security tests in sandbox env,
- **Backups and recovery** - 3-2-1 rule - 3 copies, 2 different media, 1 copy offsite storage, encrypt, test recovery, RPO - recovery point objective and RTO - recovery time objective for each type of asset, retention mng, backups also for servers and services, if one fails the other one takes over the communication,
- **Secure data removal** - clear (overwrite /w random data, delete encryption keys), purge (demagnetize hard drive), destroy (shred or physically destroy)
- **Summary:** consult with all parties involved, design architecture to implement all security policies for high level and low level technical views, configuration mng, monitor and review yearly.
- 5: Security operations
 - Obj is to meet security goals without compromising IT performance, **SecOps** team or **Sec Ops Center (SOC)** - goal is to achieve continuous protection of info,

threat prevention, quick and effective response to sec incidents, lower costs, in-house sec know-how, compliance, improved business reputation

- Tasks: asset and endpoint inventory, mng of sec controls, training and knowledge sharing, vulnerability monitoring, incident response, investigating, testing, compliance, reporting, continuous improvement,
- **asset and endpoint inventory** - identify/mng, **digital** - computers, smartphones, usb routers, iot, **physical** - windows, gates, doors, rooms.
endpoint status: secure, risky, pending assessment, out of service, compromised
- **mng of sec controls** - automatic, online, manual, mng changes, procedures for enrolling new devices and sec control on them,
- **training and knowledge sharing** - assess baseline, deliver training, simulate cyberattacks, motivational tools, monitor progress and improve,
- **vulnerability monitoring** - **digital** - use vulnerability db CVE, pen tests, detect, analyse sec (types: network, OS, apps, config), **physical** - pen tests, analyse sec. **removal of vulnerabilities:** update patches, changes in config, code, removal of systems or libs
- **incident response** - **preparation** (prepare emp, tools to act according to a plan), **identification** (report when notified), **containment** (stop the incident, disconnect devices so it doesn't spread more), **eradication** (fix the issues), **recovery** (recover normal operations), **improve** (take lessons and improve process to avoid same things in the future)
- Sec auto tools - **EDR** - Endpoint Detection and Response, **SIEM** - Security Info and Event Mng, **SOAR** - Sec Orchestration Automation and Response
- **Incident classification:** Ignored, System low priority notification, Successful/Authorized events, System low priority error, User generated error, Low relevance attack, "Bad word" matching, First time seen, Error from invalid source, Multiple user generated errors, Integrity checking warning, High importance event, Unusual error, High importance security event, Severe attack
- **Investigating sec incidents** - understand, identify root cause, determine responsibility, - 5W+H - what, when, where, why, who, and how
- **Test sec controls** - pen tests types: **physical**(reconnaissance, scoping, testing, report vulnerabilities) , **network, social engineering** (online, face to face, usb stick left), **wireless, web app, mobile app, cloud**

- **Compliance** - Dora (for fintech), EU AI act, GDPR, NIS2 (network and info systems v2)
- Reporting aaaa that! continuous secops improvement, assess everything and learn lessons
- **SecOps types:** **virtual** (internal or 3rd party operate entirely online, part-time or 24/7) **hybrid** (internal or 3rd or mix, part-time/24/7 virtual space or physical or both) **multifunction** (internal team in physical space doing secops additionally to their tasks part time 24/7) **dedicated** (fully in-house, 24/7, dedicated physical space, focusing exclusively on secops)
- **SecOps roles** - manager (oversees), engineer (or architect, builds sec systems, controls, etc.), analyst (detecting, investigating, responding to incidents), intelligence analyst (senior, monitoring, recommending revisions), tools admin (mng tools, implement, maintain)
- 6: Development of Secure software
 - **SSDLC - Secure Software Dev Lifecycle - principles:** **Sec by design** (thinking about sec right from the start), **Continuous monitoring** (regular checks and ensuring sec of soft), **Risk assessment** (evaluate, understand risks early in the dev process, id vulnerabilities), **Education and training, collaboration** (between teams, knowledge sharing, common sec goals), **Phases:** **Planning** (figure out sec req), **Design** (decide how to design security into system architecture), **Implementation** (dev using sec code practices, code reviews, fix issues), **Testing** (scanning, manual, unit), **Deployment** (release process is secure, scanning tools), **Maintenance** (soft looked after, modified, kept secure) **Best Practices:** **threat modelling** (id, analyse during design phase), **Code reviews**, **Automated Testing**, **Incident Response Planning**, **Secure Coding Guidelines**.
 - **OWASP Software Assurance Maturity Model (SAMM)** - 3 levels (usually some initial docs, then full-on guidelines, then full execution)
 - **Software Bill of Materials (SBOM)** - list of all ingredients that make up a software - libraries, tech stack etc. can be checked for vulnerabilities, **(SAST)** - **Static app sec testing** (manual or auto), **DAST** - dynamic sec test, **SLA** - **Service Level Agreement** - defines attributes of delivered soft such as availability, recovery time, time to fix

- **NIST Secure Soft Dev framework** - **PO**: Prepare org, **PS**: protect soft, **PW**: Produce well secured soft, **RV**: Respond to vulnerabilities,
- **ISO 27034: app sec**: target level of trust, actual level of trust, **ASC** app sec control, data structure containing enumeration and description of a sec activity and its associated verification measurement
- **Summary**: a few frameworks: OWASP SAMM, NIST (SSDF), ISO/IEC, They all share similar features: **risk-oriented** (risk analysis), **vulnerabilities and sec controls** (key items in sec assurance process), **proactive approach with sec coding and hardening architecture**, **strong config mng**, **toolchain for build and release**, **automatic and manual sec testing** (SAST and DAST).
- 7: Security management
 - **Information Security Management System (ISMS)** - systematic framework of processes within the org to protect assets, assure sec, basic req: formally approved in the org and strongly supported by the top mngrs, implemented and mng, cont audit and monitor, rev by mngrs and improved, **main frameworks**: NIST CSF 2.0, CIS Critical sec controls, ISO 27001, **goals**: reduce risks, improve trust, business survival, compliance and certification maybe required,
 - **ISO 27001**: best practices, risk analysis, sec controls, applicable for mid/large org, certification possible, family of standards, **ISMS req**: org context, leadership, planning, support, operation, performance evaluation, improvement, **Sec controls**: org, people, physical, technological
 - **Org controls**: organization manages and governs information security across policies, roles, assets, access, suppliers, incidents, continuity, and compliance. ensure security is consistently applied in operations, projects, external relationships, and legal requirements to maintain a reliable and accountable security posture.
 - **ppl controls**: screening, t&c of emp, training, disciplinary, termination and change of emp, NDA and confidentiality, remote working, info sec event report,
 - **phys controls**: perimeters, entry, secure offices/rooms, phys monitoring, env/phys threat protect, secure areas, clear desk/screen, equipment siting/protect, off-prem assets, storage media, utilities, cabling sec, equip maintenance, secure disposal/reuse
 - **tech controls**: endpoints, privileged access, info access restrict, src code access, secure auth, capacity mgmt, anti-malware, vuln mgmt, config mgmt, info

deletion, data masking, data leakage prev, backups, redundancy, logging, monitoring, clock sync, privileged utils, sw install control, net sec, net svc sec, net segregation, web filter, crypto, SDLC sec, app sec reqs, secure arch/eng, secure coding, sec testing, outsourced dev, dev/test/prod sep, change mgmt, test info, audit test protect

- **PDCA** - plan (id scope assets, org, risk assess, policies, processes), do (sec controls impl), check (monitor, asses performance), act (correct and prevent, improve)
- **ISO 27001 ISMS - Context of the org, leadership** (involve mngmt and let them lead everyone,), **planning** (risk treatment, sec controls, icdt response) **support** (train, educate, communication, docs), **operation** (mng threats, react to icdt), **performance evaluation** (monitor, audit, review), **improvement** (react to nonconformities, improve effectiveness and resilience)
- **Context of the org:** perspectives: business, customer, legal, local reqs, marketing, IT, relations to external orgs,
- **Leadership:** let top mngrs lead, the owner of ISMS is top mngmt not IT, IT is one of the persp, **steps:** establish info sec policy, sec obj, ensure resources, assign responsibilities, promote ISMS, review ISMS, ensure ISMS is inline with business obj and resolve conflicts - important bcs no one will care if it's only a recommendation, mngmt not involved = waste of time.
- **Policy checklist:** data protection, data retention, info sec, access control, asset mgmt, risk mgmt, info class & handling, awareness & training, acceptable use, clear desk/screen, mobile & telework, BCP, backup, malware/AV, change mgmt, supplier sec, continual improv, logging & monitoring, network sec mgmt, info transfer, secure dev, physical/env sec, crypto key mgmt, crypto/encryption, doc & record
- **Sec planning:** **risk assesment** (analyse, acceptance criteria, scope, prioritize), **risk treatment** (sec controls, **SOA** - statement of applicability: controls justification for inclusion/exclusion of them), **planning sec controls implemenation** (responsibilities, resources, communication, reporting status, risk treatment plan)
- **SoA - Statement of Applicability** - auditors ask for it, all planned and implemented sec controls, those in Annex A, explain why some are excluded, kept up to date, single most important doc in ISMS,

- **RTP - Risk treatment plan** - describes how org will tackle the id risks, summaries of risks, parties resp, outline sec controls, resources, acceptance, deadline, implementation status: 0 not impl/no plan, 1 planned not impl, 2 partial impl, 3 impl no M/R/I, 4 impl with regular M/R/I
- **ISMS Support:** provide docs, guidelines, tools, education, awareness, personnel
- **ISMS Operation:** org plans, implements, controls stuff in ISMS, everything documented, response to incidents
- **Performance evaluation:** monitor, measure, analyze, evaluate, audits internal, external. reports to mngmt, reviews annually
- **Improvement:** cont improves based on mngr reviews, audits, resolving nonconformities, conflicts, alligns with business goals,
- **Certification** for 3 years, takes a year for big org, after 3 years recertification,
- **ISO checklist:** 1 top-mgmt-approved sec policy, 2 assets ID/classed, 3 RA done/up-to-date, 4 SoA defined/up-to-date, 5 RTP defined/impl, 6 policies align w/ processes, 7 org-wide awareness training, 8 sec measures defined/monitored, 9 internal audits cover all, 10 incident response team active/doc'd, 11 mgmt reviews doc'd, 12 corrective actions doc'd/impl